

➤ **Vendor: ISACA**

➤ **Exam Code: CISA**

➤ **Exam Name: Certified Information Systems Auditor**

➤ **Question 1001 – End**

[Visit PassLeader and Download Full Version CISA Exam Dumps](#)

QUESTION 1001

To address an organization's disaster recovery requirements, backup intervals should not exceed the:

- A. service level objective (SLO).
- B. recovery time objective (RTO).
- C. recovery point objective (RPO).
- D. maximum acceptable outage (MAO).

Answer: C

Explanation:

The recovery point objective (RPO) defines the point in time to which data must be restored after a disaster so as to resume processing transactions. Backups should be performed in a way that the latest backup is no older than this maximum time frame. If service levels are not met, the usual consequences are penalty payments, not cessation of business. Organizations will try to set service level objectives (SLOs) so as to meet established targets. The resulting time for the service level agreement (SLA) will usually be longer than the RPO. The recovery time objective (RTO) defines the time period after the disaster in which normal business functionality needs to be restored. The maximum acceptable outage (MAO) is the maximum amount of system downtime that is tolerable. It can be used as a synonym for RTO. However, the RTO denotes an objective/target, while the MAO constitutes a vital necessity for an organization's survival.

QUESTION 1002

After completing the business impact analysis (BIA), what is the next step in the business continuity planning process?

- A. Test and maintain the plan.
- B. Develop a specific plan.
- C. Develop recovery strategies.
- D. implement the plan.

Answer: C

Explanation:

The next phase in the continuity plan development is to identify the various recovery strategies and select the most appropriate strategy for recovering from a disaster. After selecting a strategy, a specific plan can be developed, tested and implemented.

QUESTION 1003

Which of the following is an appropriate test method to apply to a business continuity plan (BCP)?

- A. Pilot
- B. Paper
- C. Unit
- D. System

Answer: B

Explanation:

A paper test is appropriate for testing a BCP. It is a walkthrough of the entire plan, or part of the plan, involving major players in the plan's execution, who reason out what may happen in a particular disaster. Choices A, C and D are not appropriate for a BCP.

QUESTION 1004

An IS auditor has audited a business continuity plan (BCP). Which of the following findings is the MOST critical?

- A. Nonavailability of an alternate private branch exchange (PBX) system
- B. Absence of a backup for the network backbone
- C. Lack of backup systems for the users' PCs
- D. Failure of the access card system

Answer: B

Explanation:

Failure of a network backbone will result in the failure of the complete network and impact the ability of all users to access information on the network. The nonavailability of an alternate PBX system will result in users not being able to make or receive telephone calls or faxes; however, users may have alternate means of communication, such as a mobile phone or e-mail. Lack of backup systems for user PCs will impact only the specific users, not all users. Failure of the access card system impacts the ability to maintain records of the users who are entering the specified work areas; however, this could be mitigated by manual monitoring controls.

QUESTION 1005

As part of the business continuity planning process, which of the following should be identified FIRST in the business impact analysis?

- A. Organizational risks, such as single point-of-failure and infrastructure risk
- B. Threats to critical business processes
- C. Critical business processes for ascertaining the priority for recovery
- D. Resources required for resumption of business

Answer: C

Explanation:

The identification of the priority for recovering critical business processes should be addressed first. Organizational risks should be identified next, followed by the identification of threats to critical business processes. Identification of resources for business resumption will occur after the tasks mentioned.

QUESTION 1006

Which of the following activities should the business continuity manager perform FIRST after the replacement of hardware at the primary information processing facility?

- A. Verify compatibility with the hot site.
- B. Review the implementation report.
- C. Perform a walk-through of the disaster recovery plan.
- D. Update the IS assets inventory.

Answer: D

Explanation:

An IS assets inventory is the basic input for the business continuity/disaster recovery plan, and the plan must be updated to reflect changes in the IS infrastructure. The other choices are procedures required to update the disaster recovery plan after having updated the required assets inventory.

QUESTION 1007

Which of the following would contribute MOST to an effective business continuity plan (BCP)?

- A. Document is circulated to all interested parties
- B. Planning involves all user departments
- C. Approval by senior management
- D. Audit by an external IS auditor

Answer: B

Explanation:

The involvement of user departments in the BCP is crucial for the identification of the business processing priorities. The BCP circulation will ensure that the BCP document is received by all users. Though essential, this does not contribute significantly to the success of the BCP. A BCP approved by senior management would not ensure the quality of the BCP, nor would an audit necessarily improve the quality of the BCP.

QUESTION 1008

To develop a successful business continuity plan, end user involvement is critical during which of the following phases?

- A. Business recovery strategy
- B. Detailed plan development
- C. Business impact analysis (BIA)
- D. Testing and maintenance

Answer: C

Explanation:

End user involvement is critical in the BIA phase. During this phase the current operations of the business needs to be understood and the impact on the business of various disasters must be evaluated. End users are the appropriate persons to provide relevant information for these tasks, inadequate end user involvement in this stage could result in an inadequate understanding of business priorities and the plan not meeting the requirements of the organization.

QUESTION 1009

Which of the following would an IS auditor consider to be the MOST important to review when conducting a business continuity audit?

- A. A hot site is contracted for and available as needed.

- B. A business continuity manual is available and current.
- C. insurance coverage is adequate and premiums are current.
- D. Media backups are performed on a timely basis and stored offsite.

Answer: D

Explanation:

Without data to process, all other components of the recovery effort are in vain. Even in the absence of a plan, recovery efforts of any type would not be practical without data to process.

QUESTION 1010

The PRIMARY objective of business continuity and disaster recovery plans should be to:

- A. safeguard critical IS assets.
- B. provide for continuity of operations.
- C. minimize the loss to an organization.
- D. protect human life.

Answer: D

Explanation:

Since human life is invaluable, the main priority of any business continuity and disaster recovery plan should be to protect people. All other priorities are important but are secondary objectives of a business continuity and disaster recovery plan.

QUESTION 1011

After a full operational contingency test, an IS auditor performs a review of the recovery steps. The auditor concludes that the time it took for the technological environment and systems to return to full-functioning exceeded the required critical recovery time. Which of the following should the auditor recommend?

- A. Perform an integral review of the recovery tasks.
- B. Broaden the processing capacity to gain recovery time.
- C. Make improvements in the facility's circulation structure.
- D. increase the amount of human resources involved in the recovery.

Answer: A

Explanation:

Performing an exhaustive review of the recovery tasks would be appropriate to identify the way these tasks were performed, identify the time allocated to each of the steps required to accomplish recovery, and determine where adjustments can be made. Choices B, C and D could be actions after the described review has been completed.

QUESTION 1012

Which of the following is a continuity plan test that uses actual resources to simulate a system crash to cost-effectively obtain evidence about the plan's effectiveness?

- A. Paper test
- B. Post test
- C. Preparedness test
- D. Walkthrough

Answer: C

Explanation:

A preparedness test is a localized version of a full test, wherein resources are expended in the simulation of a system crash. This test is performed regularly on different aspects of the plan and can be a cost-effective way to gradually obtain evidence about the plan's effectiveness. It also provides a means to improve the plan in increments. A paper test is a walkthrough of the plan, involving major players, who attempt to determine what might happen in a particular type of service disruption in the plan's execution. A paper test usually precedes the preparedness test. A post-test is actually a test phase and is comprised of a group of activities, such as returning all resources to their proper place, disconnecting equipment, returning personnel and deleting all company data from third-party systems. A walkthrough is a test involving a simulated disaster situation that tests the preparedness and understanding of management and staff, rather than the actual resources.

QUESTION 1013

While designing the business continuity plan (BCP) for an airline reservation system, the MOST appropriate method of data transfer/backup at an offsite location would be:

- A. shadow file processing.
- B. electronic vaulting.
- C. hard-disk mirroring.
- D. hot-site provisioning.

Answer: A

Explanation:

In shadow file processing, exact duplicates of the files are maintained at the same site or at a remote site. The two files are processed concurrently. This is used for critical data files, such as airline booking systems. Electronic vaulting electronically transmits data either to direct access storage, an optical disc or another storage medium; this is a method used by banks. Hard-disk mirroring provides redundancy in case the primary hard disk fails. All transactions and operations occur on two hard disks in the same server. A hot site is an alternate site ready to take over business operations within a few hours of any business interruption and is not a method for backing up data.

QUESTION 1014

Depending on the complexity of an organization's business continuity plan (BCP), the plan may be developed as a set of more than one plan to address various aspects of business continuity and disaster recovery, in such an environment, it is essential that:

- A. each plan is consistent with one another.
- B. all plans are integrated into a single plan.
- C. each plan is dependent on one another.
- D. the sequence for implementation of all plans is defined.

Answer: A

Explanation:

Depending on the complexity of an organization, there could be more than one plan to address various aspects of business continuity and disaster recovery. These do not necessarily have to be integrated into one single plan. However, each plan has to be consistent with other plans to have a viable business continuity planning strategy. It may not be possible to define a sequence in which plans have to be implemented, as it may be dependent on the nature of disaster, criticality, recovery time, etc.

QUESTION 1015

During a business continuity audit an IS auditor found that the business continuity plan (BCP) covered only critical processes. The IS auditor should:

- A. recommend that the BCP cover all business processes.
- B. assess the impact of the processes not covered.
- C. report the findings to the IT manager.
- D. redefine critical processes.

Answer: B

Explanation:

The business impact analysis needs to be either updated or revisited to assess the risk of not covering all processes in the plan. It is possible that the cost of including all processes might exceed the value of those processes; therefore, they should not be covered. An IS auditor should substantiate this by analyzing the risk.

QUESTION 1016

An IS auditor noted that an organization had adequate business continuity plans (BCPs) for each individual process, but no comprehensive BCP. Which would be the BEST course of action for the IS auditor?

- A. Recommend that an additional comprehensive BCP be developed.
- B. Determine whether the BCPs are consistent.
- C. Accept the BCPs as written.
- D. Recommend the creation of a single BCP.

Answer: B

Explanation:

Depending on the complexity of the organization, there could be more than one plan to address various aspects of business continuity and disaster recovery. These do not necessarily have to be integrated into one single plan; however, each plan should be consistent with other plans to have a viable business continuity planning strategy.

QUESTION 1017

When developing a business continuity plan (BCP), which of the following tools should be used to gain an understanding of the organization's business processes?

- A. Business continuity self-audit
- B. Resource recovery analysis
- C. Risk assessment
- D. Gap analysis

Answer: C

Explanation:

Risk assessment and business impact assessment are tools for understanding business- for-business continuity planning. Business continuity self-audit is a tool for evaluating the adequacy of the BCP, resource recovery analysis is a tool for identifying a business resumption strategy, while the role gap analysis can play in business continuity planning is to identify deficiencies in a plan. Neither of these is used for gaining an understanding of the business.

QUESTION 1018

During an audit of a business continuity plan (BCP), an IS auditor found that, although all departments were housed in the same building, each department had a separate BCP. The IS auditor recommended that the BCPs be reconciled. Which of the following areas should be reconciled FIRST?

- A. Evacuation plan
- B. Recovery priorities
- C. Backup storages
- D. Call tree

Answer: A

Explanation:

Protecting human resources during a disaster-related event should be addressed first. Having separate BCPs could result in conflicting evacuation plans, thus jeopardizing the safety of staff and clients. Choices B, C and D may be unique to each department and could be addressed separately, but still should be reviewed for possible conflicts and/or the possibility of cost reduction, but only after the issue of human safety has been analyzed.

QUESTION 1019

Management considered two projections for its business continuity plan; plan A with two months to recover and plan B with eight months to recover. The recovery objectives are the same in both plans. It is reasonable to expect that plan B projected higher:

- A. downtime costs.
- B. resumption costs.
- C. recovery costs.
- D. walkthrough costs.

Answer: A

Explanation:

Since the recovery time is longer in plan B, resumption and recovery costs can be expected to be lower. Walkthrough costs are not a part of disaster recovery. Since the management considered a higher window for recovery in plan B, downtime costs included in the plan are likely to be higher.

QUESTION 1020

The optimum business continuity strategy for an entity is determined by the:

- A. lowest downtime cost and highest recovery cost.
- B. lowest sum of downtime cost and recovery cost.
- C. lowest recovery cost and highest downtime cost.
- D. average of the combined downtime and recovery cost.

Answer: B

Explanation:

Both costs have to be minimized, and the strategy for which the costs are lowest is the optimum strategy. The strategy with the highest recovery cost cannot be the optimum strategy. The strategy with the highest downtime cost cannot be the optimum strategy. The average of the combined downtime and recovery cost will be higher than the lowest combined cost of downtime and recovery.

QUESTION 1021

The PRIMARY objective of testing a business continuity plan is to:

- A. familiarize employees with the business continuity plan.
- B. ensure that all residual risks are addressed.
- C. exercise all possible disaster scenarios.
- D. identify limitations of the business continuity plan.

Answer: D

Explanation:

Testing the business continuity plan provides the best evidence of any limitations that may exist. Familiarizing employees with the business continuity plan is a secondary benefit of a test. It is not cost effective to address residual risks in a business continuity plan, and it is not practical to test all possible disaster scenarios.

QUESTION 1022

In determining the acceptable time period for the resumption of critical business processes:

- A. only downtime costs need to be considered.
- B. recovery operations should be analyzed.
- C. both downtime costs and recovery costs need to be evaluated.
- D. indirect downtime costs should be ignored.

Answer: C

Explanation:

Both downtime costs and recovery costs need to be evaluated in determining the acceptable time period before the resumption of critical business processes. The outcome of the business impact analysis (BIA) should be a recovery strategy that represents the optimal balance. Downtime costs cannot be looked at in isolation. The quicker information assets can be restored and business processing resumed, the smaller the downtime costs. However, the expenditure needed to have the redundant capability required to recover information resources might be prohibitive for nonessential business processes. Recovery operations do not determine the acceptable time period for the resumption of critical business processes, and indirect downtime costs should be considered in addition to the direct cash outflows incurred due to business disruption. The indirect costs of a serious disruption to normal business activity, e.g., loss of customer and supplier goodwill and loss of market share, may actually be more significant than direct costs over time, thus reaching the point where business viability is threatened.

QUESTION 1023

In the event of a disruption or disaster, which of the following technologies provides for continuous operations?

- A. Load balancing
- B. Fault-tolerant hardware
- C. Distributed backups
- D. High-availability computing

Answer: B

Explanation:

Fault-tolerant hardware is the only technology that currently supports continuous, uninterrupted service. Load balancing is used to improve the performance of the server by splitting the work between several servers based on workloads. High-availability (HA) computing facilities provide a quick but not continuous recovery, while distributed backups require longer recovery times.

QUESTION 1024

Which of the following would be MOST important for an IS auditor to verify when conducting a business continuity audit?

- A. Data backups are performed on a timely basis
- B. A recovery site is contracted for and available as needed
- C. Human safety procedures are in place

D. insurance coverage is adequate and premiums are current

Answer: C

Explanation:

The most important element in any business continuity process is the protection of human life. This takes precedence over all other aspects of the plan.

QUESTION 1025

Which of the following insurance types provide for a loss arising from fraudulent acts by employees?

- A. Business interruption
- B. Fidelity coverage
- C. Errors and omissions
- D. Extra expense

Answer: B

Explanation:

Fidelity insurance covers the loss arising from dishonest or fraudulent acts by employees. Business interruption insurance covers the loss of profit due to the disruption in the operations of an organization. Errors and omissions insurance provides legal liability protection in the event that the professional practitioner commits an act that results in financial loss to a client. Extra expense insurance is designed to cover the extra costs of continuing operations following a disaster/disruption within an organization.

QUESTION 1026

The BEST method for assessing the effectiveness of a business continuity plan is to review the:

- A. plans and compare them to appropriate standards.
- B. results from previous tests.
- C. emergency procedures and employee training.
- D. offsite storage and environmental controls.

Answer: B

Explanation:

Previous test results will provide evidence of the effectiveness of the business continuity plan. Comparisons to standards will give some assurance that the plan addresses the critical aspects of a business continuity plan but will not reveal anything about its effectiveness. Reviewing emergency procedures, offsite storage and environmental controls would provide insight into some aspects of the plan but would fall short of providing assurance of the plan's overall effectiveness.

QUESTION 1027

With respect to business continuity strategies, an IS auditor interviews key stakeholders in an organization to determine whether they understand their roles and responsibilities. The IS auditor is attempting to evaluate the:

- A. clarity and simplicity of the business continuity plans.
- B. adequacy of the business continuity plans.
- C. effectiveness of the business continuity plans.
- D. ability of IS and end-user personnel to respond effectively in emergencies.

Answer: A

Explanation:

The IS auditor should interview key stakeholders to evaluate how well they understand their roles

and responsibilities. When all stakeholders have a detailed understanding of their roles and responsibilities in the event of a disaster, an IS auditor can deem the business continuity plan to be clear and simple. To evaluate adequacy, the IS auditor should review the plans and compare them to appropriate standards. To evaluate effectiveness, the IS auditor should review the results from previous tests. This is the best determination for the evaluation of effectiveness. An understanding of roles and responsibilities by key stakeholders will assist in ensuring the business continuity plan is effective. To evaluate the response, the IS auditor should review results of continuity tests. This will provide the IS auditor with assurance that target and recovery times are met. Emergency procedures and employee training need to be reviewed to determine whether the organization had implemented plans to allow for the effective response.

QUESTION 1028

During the design of a business continuity plan, the business impact analysis (BIA) identifies critical processes and supporting applications. This will PRIMARILY influence the:

- A. responsibility for maintaining the business continuity plan.
- B. criteria for selecting a recovery site provider.
- C. recovery strategy.
- D. responsibilities of key personnel.

Answer: C

Explanation:

The most appropriate strategy is selected based on the relative risk level and criticality identified in the business impact analysis (BIA.) The other choices are made after the selection or design of the appropriate recovery strategy.

QUESTION 1029

During a review of a business continuity plan, an IS auditor noticed that the point at which a situation is declared to be a crisis has not been defined. The MAJOR risk associated with this is that:

- A. assessment of the situation may be delayed.
- B. execution of the disaster recovery plan could be impacted.
- C. notification of the teams might not occur.
- D. potential crisis recognition might be ineffective.

Answer: B

Explanation:

Execution of the business continuity plan would be impacted if the organization does not know when to declare a crisis. Choices A, C and D are steps that must be performed to know whether to declare a crisis. Problem and severity assessment would provide information necessary in declaring a disaster. Once a potential crisis is recognized, the teams responsible for crisis management need to be notified. Delaying this step until a disaster has been declared would negate the effect of having response teams. Potential crisis recognition is the first step in responding to a disaster.

QUESTION 1030

An organization has just completed their annual risk assessment. Regarding the business continuity plan, what should an IS auditor recommend as the next step for the organization?

- A. Review and evaluate the business continuity plan for adequacy
- B. Perform a full simulation of the business continuity plan
- C. Train and educate employees regarding the business continuity plan
- D. Notify critical contacts in the business continuity plan

Answer: A

Explanation:

The business continuity plan should be reviewed every time a risk assessment is completed for the organization. Training of the employees and a simulation should be performed after the business continuity plan has been deemed adequate for the organization. There is no reason to notify the business continuity plan contacts at this time.

QUESTION 1031

Integrating business continuity planning (BCP) into an IT project aids in:

- A. the retrofitting of the business continuity requirements.
- B. the development of a more comprehensive set of requirements.
- C. the development of a transaction flowchart.
- D. ensuring the application meets the user's needs.

Answer: B

Explanation:

Integrating business continuity planning (BCP) into the development process ensures complete coverage of the requirements through each phase of the project. Retrofitting of the business continuity plan's requirements occurs when BCP is not integrating into the development methodology. Transaction flowcharts aid in analyzing an application's controls. A business continuity plan will not directly address the detailed processing needs of the users.

QUESTION 1032

While observing a full simulation of the business continuity plan, an IS auditor notices that the notification systems within the organizational facilities could be severely impacted by infra structural damage. The BEST recommendation the IS auditor can provide to the organization is to ensure:

- A. the salvage team is trained to use the notification system.
- B. the notification system provides for the recovery of the backup.
- C. redundancies are built into the notification system.
- D. the notification systems are stored in a vault.

Answer: C

QUESTION 1033

The activation of an enterprise's business continuity plan should be based on predetermined criteria that address the:

- A. duration of the outage.
- B. type of outage.
- C. probability of the outage.
- D. cause of the outage.

Answer: A

Explanation:

The initiation of a business continuity plan (action) should primarily be based on the maximum period for which a business function can be disrupted before the disruption threatens the achievement of organizational objectives.

QUESTION 1034

An organization has outsourced its wide area network (WAN) to a third-party service provider.

Under these circumstances, which of the following is the PRIMARY task the IS auditor should perform during an audit of business continuity (BCP) and disaster recovery planning (DRP)?

- A. Review whether the service provider's BCP process is aligned with the organization's BCP and contractual obligations.
- B. Review whether the service level agreement (SLA) contains a penalty clause in case of failure to meet the level of service in case of a disaster.
- C. Review the methodology adopted by the organization in choosing the service provider.
- D. Review the accreditation of the third-party service provider's staff.

Answer: A

Explanation:

Reviewing whether the service provider's business continuity plan (BCP) process is aligned with the organization's BCP and contractual obligations is the correct answer since an adverse effect or disruption to the business of the service provider has a direct bearing on the organization and its customers. Reviewing whether the service level agreement (SLA) contains a penalty clause in case of failure to meet the level of service in case of a disaster is not the correct answer since the presence of penalty clauses, although an essential element of a SLA, is not a primary concern. Choices C and D are possible concerns, but of lesser importance.

QUESTION 1035

An IS auditor can verify that an organization's business continuity plan (BCP) is effective by reviewing the:

- A. alignment of the BCP with industry best practices.
- B. results of business continuity tests performed by IS and end-user personnel.
- C. off-site facility, its contents, security and environmental controls.
- D. annual financial cost of the BCP activities versus the expected benefit of implementation of the plan.

Answer: B

Explanation:

The effectiveness of the business continuity plan (BCP) can best be evaluated by reviewing the results from previous business continuity tests for thoroughness and accuracy in accomplishing their stated objectives. All other choices do not provide the assurance of the effectiveness of the BCP.

QUESTION 1036

To optimize an organization's business contingency plan (BCP), an IS auditor should recommend conducting a business impact analysis (BIA) in order to determine:

- A. the business processes that generate the most financial value for the organization and therefore must be recovered first.
- B. the priorities and order for recovery to ensure alignment with the organization's business strategy.
- C. the business processes that must be recovered following a disaster to ensure the organization's survival.
- D. the priorities and order of recovery which will recover the greatest number of systems in the shortest time frame.

Answer: C

Explanation:

To ensure the organization's survival following a disaster, it is important to recover the most critical business processes first, it is a common mistake to overemphasize value (A) rather than urgency. For example, while the processing of incoming mortgage loan payments is important from a

financial perspective, it could be delayed for a few days in the event of a disaster. On the other hand, wiring funds to close on a loan, while not generating direct revenue, is far more critical because of the possibility of regulatory problems, customer complaints and reputation issues. Choices B and D are not correct because neither the long-term business strategy nor the mere number of recovered systems has a direct impact at this point in time.

QUESTION 1037

A financial services organization is developing and documenting business continuity measures. In which of the following cases would an IS auditor MOST likely raise an issue?

- A. The organization uses good practice guidelines instead of industry standards and relies on external advisors to ensure the adequacy of the methodology.
- B. The business continuity capabilities are planned around a carefully selected set of scenarios which describe events that might happen with a reasonable probability.
- C. The recovery time objectives (RTOs) do not take IT disaster recovery constraints into account, such as personnel or system dependencies during the recovery phase.
- D. The organization plans to rent a shared alternate site with emergency workplaces which has only enough room for half of the normal staff.

Answer: B

Explanation:

It is a common mistake to use scenario planning for business continuity. The problem is that it is impossible to plan and document actions for every possible scenario. Planning for just selected scenarios denies the fact that even improbable events can cause an organization to break down. Best practice planning addresses the four possible areas of impact in a disaster: premises, people, systems, and suppliers and other dependencies. All scenarios can be reduced to these four categories and can be handled simultaneously. There are very few special scenarios which justify an additional separate analysis, it is a good idea to use best practices and external advice for such an important topic, especially since knowledge of the right level of preparedness and the judgment about adequacy of the measures taken is not available in every organization. The recovery time objectives (RTOs) are based on the essential business processes required to ensure the organization's survival, therefore it would be inappropriate for them to be based on IT capabilities. Best practice guidelines recommend having 20%-40% of normal capacity available at an emergency site; therefore, a value of 50% would not be a problem if there are no additional factors.

QUESTION 1038

A medium-sized organization, whose IT disaster recovery measures have been in place and regularly tested for years, has just developed a formal business continuity plan (BCP). A basic BCP tabletop exercise has been performed successfully. Which testing should an IS auditor recommend be performed NEXT to verify the adequacy of the new BCP?

- A. Full-scale test with relocation of all departments, including IT, to the contingency site
- B. Walk-through test of a series of predefined scenarios with all critical personnel involved
- C. IT disaster recovery test with business departments involved in testing the critical applications
- D. Functional test of a scenario with limited IT involvement

Answer: D

Explanation:

After a tabletop exercise has been performed, the next step would be a functional test, which includes the mobilization of staff to exercise the administrative and organizational functions of a recovery. Since the IT part of the recovery has been tested for years, it would be more efficient to verify and optimize the business continuity plan (BCP) before actually involving IT in a full-scale test. The full-scale test would be the last step of the verification process before entering into a

regular annual testing schedule. A full-scale test in the situation described might fail because it would be the first time that the plan is actually exercised, and a number of resources (including IT) and time would be wasted. The walk-through test is the most basic type of testing. Its intention is to make key staff familiar with the plan and discuss critical plan elements, rather than verifying its adequacy. The recovery of applications should always be verified and approved by the business instead of being purely IT-driven. A disaster recovery test would not help in verifying the administrative and organizational parts of the BCP which are not IT-related.

QUESTION 1039

Everything not explicitly permitted is forbidden has which of the following kinds of tradeoff?

- A. it improves security at a cost in functionality.
- B. it improves functionality at a cost in security.
- C. it improves security at a cost in system performance.
- D. it improves performance at a cost in functionality.
- E. None of the choices.

Answer: A

Explanation:

"Everything not explicitly permitted is forbidden (default deny) improves security at a cost in functionality. This is a good approach if you have lots of security threats. On the other hand., ""Everything not explicitly forbidden is permitted"" (default permit) allows greater functionality by sacrificing security. This is only a good approach in an environment where security threats are non-existent or negligible."

QUESTION 1040

Default permit is only a good approach in an environment where:

- A. security threats are non-existent or negligible.
- B. security threats are non-negligible.
- C. security threats are serious and severe.
- D. users are trained.
- E. None of the choices.

Answer: A

Explanation:

"Everything not explicitly permitted is forbidden (default deny) improves security at a cost in functionality. This is a good approach if you have lots of security threats. On the other hand., ""Everything not explicitly forbidden is permitted"" (default permit) allows greater functionality by sacrificing security. This is only a good approach in an environment where security threats are non-existent or negligible."

QUESTION 1041

Talking about the different approaches to security in computing, the principle of regarding the computer system itself as largely an untrusted system emphasizes:

- A. most privilege
- B. full privilege
- C. least privilege
- D. null privilege
- E. None of the choices.

Answer: C

Explanation:

There are two different approaches to security in computing. One focuses mainly on external threats, and generally treats the computer system itself as a trusted system. The other regards the computer system itself as largely an untrusted system, and redesigns it to make it more secure in a number of ways.

This technique enforces the principle of least privilege to great extent, where an entity has only the privileges that are needed for its function.

QUESTION 1042

Which of the following refers to the proving of mathematical theorems by a computer program?

- A. Analytical theorem proving
- B. Automated technology proving
- C. Automated theorem processing
- D. Automated theorem proving
- E. None of the choices.

Answer: D

Explanation:

Automated theorem proving (ATP) is the proving of mathematical theorems by a computer program. Depending on the underlying logic, the problem of deciding the validity of a theorem varies from trivial to impossible. Commercial use of automated theorem proving is mostly concentrated in integrated circuit design and verification.

QUESTION 1043

"Which of the following BEST describes the concept of ""defense in depth""?"

- A. more than one subsystem needs to be compromised to compromise the security of the system and the information it holds.
- B. multiple firewalls are implemented.
- C. multiple firewalls and multiple network OS are implemented.
- D. intrusion detection and firewall filtering are required.
- E. None of the choices.

Answer: A

Explanation:

"With 0""defense in depth"", more than one subsystem needs to be compromised to compromise the security of the system and the information it holds. Subsystems should default to secure settings, and wherever possible should be designed to ""fail secure"" rather than ""fail insecure""."

QUESTION 1044

"Under the concept of ""defense in depth"", subsystems should be designed to:"

- A. ""fail insecure""
- B. ""fail secure""
- C. ""react to attack""
- D. ""react to failure""
- E. None of the choices.

Answer: B

Explanation:

"With 0""defense in depth"", more than one subsystem needs to be compromised to compromise the security of the system and the information it holds. Subsystems should default to secure settings, and wherever possible should be designed to ""fail secure"" rather than ""fail insecure""."

QUESTION 1045

Security should ALWAYS be an all or nothing issue.

- A. True
- B. True for trusted systems only
- C. True for untrusted systems only
- D. False
- E. None of the choices.

Answer: D

Explanation:

Security should not be an all or nothing issue. The designers and operators of systems should assume that security breaches are inevitable in the long term. Full audit trails should be kept of system activity, so that when a security breach occurs, the mechanism and extent of the breach can be determined.

QUESTION 1046

The 'trusted systems' approach has been predominant in the design of:

- A. many earlier Microsoft OS products
- B. the IBM AS/400 series
- C. the SUN Solaris series
- D. most OS products in the market
- E. None of the choices.

Answer: A

Explanation:

The 'trusted systems' approach has been predominant in the design of many Microsoft OS products, due to the long-standing Microsoft policy of emphasizing functionality and 'ease of use'.

QUESTION 1047

Which of the following terms generally refers to small programs designed to take advantage of a software flaw that has been discovered?

- A. exploit
- B. patch
- C. quick fix
- D. service pack
- E. malware
- F. None of the choices.

Answer: A

Explanation:

"The term ""exploit"" generally refers to small programs designed to take advantage of a software flaw that has been discovered, either remote or local. The code from the exploit program is frequently reused in trojan horses and computer viruses. In some cases, a vulnerability can lie in a certain programs processing of a specific file type, such as a non-executable media file."

QUESTION 1048

Codes from exploit programs are frequently reused in:

- A. trojan horses only.
- B. computer viruses only.
- C. OS patchers.
- D. eavedroppers.
- E. trojan horses and computer viruses.
- F. None of the choices.

Answer: E

Explanation:

"The term ""exploit"" generally refers to small programs designed to take advantage of a software flaw that has been discovered, either remote or local. The code from the exploit program is frequently reused in trojan horses and computer viruses. In some cases, a vulnerability can lie in a certain programs processing of a specific file type, such as a non-executable media file."

QUESTION 1049

Machines that operate as a closed system can NEVER be eavesdropped.

- A. True
- B. False

Answer: B

Explanation:

Any data that is transmitted over a network is at some risk of being eavesdropped, or even modified by a malicious person. Even machines that operate as a closed system can be eavesdropped upon via monitoring the faint electromagnetic transmissions generated by the hardware such as TEMPEST.

QUESTION 1050

TEMPEST is a hardware for which of the following purposes?

- A. Eavesdropping
- B. Social engineering
- C. Virus scanning
- D. Firewalling
- E. None of the choices.

Answer: A

Explanation:

Any data that is transmitted over a network is at some risk of being eavesdropped, or even modified by a malicious person. Even machines that operate as a closed system can be eavesdropped upon via monitoring the faint electromagnetic transmissions generated by the hardware such as TEMPEST.

QUESTION 1051

Human error is being HEAVILY relied upon on by which of the following types of attack?

- A. Eavesdropping
- B. DoS
- C. DDoS

- D. ATP
- E. Social Engineering
- F. None of the choices.

Answer: E

QUESTION 1052

A computer system is no more secure than the human systems responsible for its operation. Malicious individuals have regularly penetrated well-designed, secure computer systems by taking advantage of the carelessness of trusted individuals, or by deliberately deceiving them. zombie computers are being HEAVILY relied upon on by which of the following types of attack?

- A. Eavedropping
- B. DoS
- C. DDoS
- D. ATP
- E. Social Engineering
- F. None of the choices.

Answer: C

Explanation:

"Distributed denial of service (DDoS) attacks are common, where a large number of compromised hosts ("zombie computers") are used to flood a target system with network requests, thus attempting to render it unusable through resource exhaustion."

QUESTION 1053

Attack amplifier is often being HEAVILY relied upon on by which of the following types of attack?

- A. Packet dropping
- B. ToS
- C. DDoS
- D. ATP
- E. Wiretapping
- F. None of the choices.

Answer: C

Explanation:

Distributed denial of service (DDoS) attacks are common, where a large number of compromised hosts are used to flood a target system with network requests. One technique to exhaust victim resources is through the use of an attack amplifier - where the attacker takes advantage of poorly designed protocols on 3rd party machines in order to instruct these hosts to launch the flood.

QUESTION 1054

Back Orifice is an example of:

- A. a virus.
- B. a legitimate remote control software.
- C. a backdoor that takes the form of an installed program.
- D. an eaveddropper.
- E. None of the choices.

Answer: C

Explanation:

"A backdoor may take the form of an installed program (e.g., Back Orifice) or could be in the form of an existing ""legitimate"" program, or executable file. A specific form of backdoors are rootkits, which replaces system binaries and/or hooks into the function calls of the operating system to hide the presence of other programs, users, services and open ports."

QUESTION 1055

Which of the following will replace system binaries and/or hook into the function calls of the operating system to hide the presence of other programs (choose the most precise answer)?

- A. rootkits
- B. virus
- C. trojan
- D. tripwire
- E. None of the choices.

Answer: A

Explanation:

"A backdoor may take the form of an installed program (e.g., Back Orifice) or could be in the form of an existing ""legitimate"" program, or executable file. A specific form of backdoors are rootkits, which replaces system binaries and/or hooks into the function calls of the operating system to hide the presence of other programs, users, services and open ports."

QUESTION 1056

Which of the following types of attack makes use of common consumer devices that can be used to transfer data surreptitiously?

- A. Direct access attacks
- B. Indirect access attacks
- C. Port attack
- D. Window attack
- E. Social attack
- F. None of the choices.

Answer: A

Explanation:

Direct access attacks make use of common consumer devices that can be used to transfer data surreptitiously. Someone gaining physical access to a computer can install all manner of devices to compromise security, including operating system modifications, software worms, keyboard loggers, and covert listening devices. The attacker can also easily download large quantities of data onto backup media or portable devices.

QUESTION 1057

Which of the following types of attack almost always requires physical access to the targets?

- A. Direct access attack
- B. Wireless attack
- C. Port attack
- D. Window attack
- E. System attack
- F. None of the choices.

Answer: A

Explanation:

Direct access attacks make use of common consumer devices that can be used to transfer data surreptitiously. Someone gaining physical access to a computer can install all manner of devices to compromise security, including operating system modifications, software worms, keyboard loggers, and covert listening devices. The attacker can also easily download large quantities of data onto backup media or portable devices.

QUESTION 1058

Which of the following methods of encryption has been proven to be almost unbreakable when correctly used?

- A. key pair
- B. Oakley
- C. certificate
- D. 3-DES
- E. one-time pad
- F. None of the choices.

Answer: E

Explanation:

It's possible to protect messages in transit by means of cryptography. One method of encryption - the one-time pad --has been proven to be unbreakable when correctly used. This method uses a matching pair of key- codes, securely distributed, which are used once-and-only-once to encode and decode a single message. Note that this method is difficult to use securely, and is highly inconvenient as well.

QUESTION 1059

Which of the following encryption methods uses a matching pair of key-codes, securely distributed, which are used once-and-only-once to encode and decode a single message?

- A. Blowfish
- B. Tripwire
- C. certificate
- D. DES
- E. one-time pad
- F. None of the choices.

Answer: E

Explanation:

It's possible to protect messages in transit by means of cryptography. One method of encryption - the one-time pad --has been proven to be unbreakable when correctly used. This method uses a matching pair of key- codes, securely distributed, which are used once-and-only-once to encode and decode a single message. Note that this method is difficult to use securely, and is highly inconvenient as well.

QUESTION 1060

Why is one-time pad not always preferable for encryption (choose all that apply):

- A. it is difficult to use securely.
- B. it is highly inconvenient to use.
- C. it requires licensing fee.

- D. it requires internet connectivity.
- E. it is Microsoft only.
- F. None of the choices.

Answer: AB

Explanation:

It's possible to protect messages in transit by means of cryptography. One method of encryption - the one-time pad - has been proven to be unbreakable when correctly used. This method uses a matching pair of key- codes, securely distributed, which are used once-and-only-once to encode and decode a single message. Note that this method is difficult to use securely, and is highly inconvenient as well.

QUESTION 1061

You may reduce a cracker's chances of success by (choose all that apply):

- A. keeping your systems up to date using a security scanner.
- B. hiring competent people responsible for security to scan and update your systems.
- C. using multiple firewalls.
- D. using multiple firewalls and IDS.
- E. None of the choices.

Answer: AB

Explanation:

Only a small fraction of computer program code is mathematically proven, or even goes through comprehensive information technology audits or inexpensive but extremely valuable computer security audits, so it is quite possible for a determined cracker to read, copy, alter or destroy data in well secured computers, albeit at the cost of great time and resources. You may reduce a cracker's chances by keeping your systems up to date, using a security scanner or/and hiring competent people responsible for security.

QUESTION 1062

Which of the following measures can protect systems files and data, respectively?

- A. User account access controls and cryptography
- B. User account access controls and firewall
- C. User account access controls and IPS
- D. IDS and cryptography
- E. Firewall and cryptography
- F. None of the choices.

Answer: A

Explanation:

User account access controls and cryptography can protect systems files and data, respectively. On the other hand, firewalls are by far the most common prevention systems from a network security perspective as they can shield access to internal network services, and block certain kinds of attacks through packet filtering.

QUESTION 1063

Which of the following is by far the most common prevention system from a network security perspective?

- A. Firewall

- B. IDS
- C. IPS
- D. Hardened OS
- E. Tripwire
- F. None of the choices.

Answer: A

Explanation:

User account access controls and cryptography can protect systems files and data, respectively. On the other hand, firewalls are by far the most common prevention systems from a network security perspective as they can shield access to internal network services, and block certain kinds of attacks through packet filtering.

QUESTION 1064

Which of the following are designed to detect network attacks in progress and assist in post-attack forensics?

- A. Intrusion Detection Systems
- B. Audit trails
- C. System logs
- D. Tripwire
- E. None of the choices.

Answer: A

Explanation:

Intrusion Detection Systems are designed to detect network attacks in progress and assist in post-attack forensics, while audit trails and logs serve a similar function for individual systems.

QUESTION 1065

"Nowadays, computer security comprises mainly "preventive"" measures."

- A. True
- B. True only for trusted networks
- C. True only for untrusted networks
- D. False
- E. None of the choices.

Answer: A

Explanation:

"Nowadays, computer security comprises mainly ""preventive"" measures, like firewalls or an Exit Procedure. A firewall can be defined as a way of filtering network data between a host or a network and another network and is normally implemented as software running on the machine or as physical integrated hardware."

QUESTION 1066

The majority of software vulnerabilities result from a few known kinds of coding defects, such as (choose all that apply):

- A. buffer overflows
- B. format string vulnerabilities
- C. integer overflow
- D. code injection

- E. command injection
- F. None of the choices.

Answer: ABCDE

Explanation:

The majority of software vulnerabilities result from a few known kinds of coding defects. Common software defects include buffer overflows, format string vulnerabilities, integer overflow, and code/command injection. Some common languages such as C and C++ are vulnerable to all of these defects. Languages such as Java are immune to some of these defects but are still prone to code/ command injection and other software defects which lead to software vulnerabilities.

QUESTION 1067

ALL computer programming languages are vulnerable to command injection attack.

- A. True
- B. False

Answer: B

Explanation:

The majority of software vulnerabilities result from a few known kinds of coding defects. Common software defects include buffer overflows, format string vulnerabilities, integer overflow, and code/command injection. Some common languages such as C and C++ are vulnerable to all of these defects. Languages such as Java are immune to some of these defects but are still prone to code/ command injection and other software defects which lead to software vulnerabilities.

QUESTION 1068

Which of the following refers to an anomalous condition where a process attempts to store data beyond the boundaries of a fixed length buffer?

- A. buffer overflow
- B. format string vulnerabilities
- C. integer misappropriation
- D. code injection
- E. None of the choices.

Answer: A

Explanation:

A buffer overflow is an anomalous condition where a process attempts to store data beyond the boundaries of a fixed length buffer. The result is that the extra data overwrites adjacent memory locations. The overwritten data may include other buffers, variables and program flow data.

QUESTION 1069

Buffer overflow aims primarily at corrupting:

- A. system processor
- B. network firewall
- C. system memory
- D. disk storage
- E. None of the choices.

Answer: C

Explanation:

A buffer overflow is an anomalous condition where a process attempts to store data beyond the boundaries of a fixed length buffer. The result is that the extra data overwrites adjacent memory locations. The overwritten data may include other buffers, variables and program flow data.

QUESTION 1070

Which of the following measures can effectively minimize the possibility of buffer overflows?

- A. Sufficient bounds checking
- B. Sufficient memory
- C. Sufficient processing capability
- D. Sufficient code injection
- E. None of the choices.

Answer: A

Explanation:

Buffer overflows may cause a process to crash or produce incorrect results. They can be triggered by inputs specifically designed to execute malicious code or to make the program operate in an unintended way. As such, buffer overflows cause many software vulnerabilities and form the basis of many exploits. Sufficient bounds checking by either the programmer or the compiler can prevent buffer overflows.

QUESTION 1071

Which of the following types of attack makes use of unfiltered user input as the format string parameter in the printf() function of the C language?

- A. buffer overflows
- B. format string vulnerabilities
- C. integer overflow
- D. code injection
- E. command injection
- F. None of the choices.

Answer: B

Explanation:

Format string attacks are a new class of vulnerabilities recently discovered. It can be used to crash a program or to execute harmful code. The problem stems from the use of unfiltered user input as the format string parameter in certain C functions that perform formatting, such as printf(). A malicious user may use the %s and %x format tokens, among others, to print data from the stack or possibly other locations in memory. One may also write arbitrary data to arbitrary locations using the %n format token.

QUESTION 1072

Which of the following kinds of function are particularly vulnerable to format string attacks?

- A. C functions that perform output formatting
- B. C functions that perform integer computation
- C. C functions that perform real number subtraction
- D. VB functions that perform integer conversion
- E. SQL functions that perform string conversion
- F. SQL functions that perform text conversion

Answer: A

Explanation:

Format string attacks are a new class of vulnerabilities recently discovered. It can be used to crash a program or to execute harmful code. The problem stems from the use of unfiltered user input as the format string parameter in certain C functions that perform formatting, such as printf(). A malicious user may use the %s and %x format tokens, among others, to print data from the stack or possibly other locations in memory. One may also write arbitrary data to arbitrary locations using the %n format token.

QUESTION 1073

Integer overflow occurs primarily with:

- A. string formatting
- B. debug operations
- C. output formatting
- D. input verifications
- E. arithmetic operations
- F. None of the choices.

Answer: E

Explanation:

An integer overflow occurs when an arithmetic operation attempts to create a numeric value that is larger than can be represented within the available storage space. On some processors the result saturates - once the maximum value is reached attempts to make it larger simply return the maximum result.

QUESTION 1074

Which of the following types of attack works by taking advantage of the unenforced and unchecked assumptions the system makes about its inputs?

- A. format string vulnerabilities
- B. integer overflow
- C. code injection
- D. command injection
- E. None of the choices.

Answer: C

Explanation:

Code injection is a technique to introduce code into a computer program or system by taking advantage of the unenforced and unchecked assumptions the system makes about its inputs.

QUESTION 1075

Which of the following terms refers to systems designed to detect and prevent the unauthorized transmission of information from the computer systems of an organization to outsiders?

- A. ILD&P
- B. ICT&P
- C. ILP&C
- D. ILR&D
- E. None of the choices.

Answer: A

Explanation:

Information Leakage Detection and Prevention (ILD&P) is a computer security term referring to systems designed to detect and prevent the unauthorized transmission of information from the computer systems of an organization to outsiders. Network ILD&P are gateway-based systems installed on the organization's internet network connection and analyze network traffic to search for unauthorized information transmissions. Host Based ILD&P systems run on end-user workstations to monitor and control access to physical devices and access information before it has been encrypted.

QUESTION 1076

Network ILD&P are typically installed:

- A. on the organization's internal network connection.
- B. on the organization's internet network connection.
- C. on each end user stations.
- D. on the firewall.
- E. None of the choices.

Answer: B

Explanation:

Information Leakage Detection and Prevention (ILD&P) is a computer security term referring to systems designed to detect and prevent the unauthorized transmission of information from the computer systems of an organization to outsiders. Network ILD&P are gateway-based systems installed on the organization's internet network connection and analyze network traffic to search for unauthorized information transmissions. Host Based ILD&P systems run on end-user workstations to monitor and control access to physical devices and access information before it has been encrypted.

QUESTION 1077

Host Based ILD&P primarily addresses the issue of:

- A. information integrity
- B. information accuracy
- C. information validity
- D. information leakage
- E. None of the choices.

Answer: D

Explanation:

Information Leakage Detection and Prevention (ILD&P) is a computer security term referring to systems designed to detect and prevent the unauthorized transmission of information from the computer systems of an organization to outsiders. Network ILD&P are gateway-based systems installed on the organization's internet network connection and analyze network traffic to search for unauthorized information transmissions. Host Based ILD&P systems run on end-user workstations to monitor and control access to physical devices and access information before it has been encrypted.

QUESTION 1078

Software is considered malware based on:

- A. the intent of the creator.
- B. its particular features.

- C. its location.
- D. its compatibility.
- E. None of the choices.

Answer: A

Explanation:

Malware is software designed to infiltrate or damage a computer system without the owner's informed consent. Software is considered malware based on the intent of the creator rather than any particular features. It includes computer viruses, worms, trojan horses, spyware, adware, and other malicious and unwanted software.

QUESTION 1079

Which of the following are valid examples of Malware (choose all that apply):

- A. viruses
- B. worms
- C. trojan horses
- D. spyware
- E. All of the above

Answer: E

Explanation:

Malware is software designed to infiltrate or damage a computer system without the owner's informed consent. Software is considered malware based on the intent of the creator rather than any particular features. It includes computer viruses, worms, trojan horses, spyware, adware, and other malicious and unwanted software.

QUESTION 1080

Which of the following refers to any program that invites the user to run it but conceals a harmful or malicious payload?

- A. virus
- B. worm
- C. trojan horse
- D. spyware
- E. rootkits
- F. None of the choices.

Answer: C

QUESTION 1081

Broadly speaking, a Trojan horse is any program that invites the user to run it, but conceals a harmful or malicious payload. The payload may take effect immediately and can lead to immediate yet undesirable effects, or more commonly it may install further harmful software into the user's system to serve the creator's longer-term goals. A Trojan horse's payload would almost always take damaging effect immediately.

- A. True
- B. False

Answer: B

Explanation:

Broadly speaking, a Trojan horse is any program that invites the user to run it, but conceals a harmful or malicious payload. The payload may take effect immediately and can lead to immediate yet undesirable effects, or more commonly it may install further harmful software into the user's system to serve the creator's longer-term goals.

QUESTION 1082

Which of the following terms is used more generally for describing concealment routines in a malicious program?

- A. virus
- B. worm
- C. trojan horse
- D. spyware
- E. rootkits
- F. backdoor
- G. None of the choices.

Answer: E

Explanation:

Rootkits can prevent a malicious process from being reported in the process table, or keep its files from being read. Originally, a rootkit was a set of tools installed by a human attacker on a Unix system where the attacker had gained administrator access. Today, the term is used more generally for concealment routines in a malicious program.

QUESTION 1083

Which of the following refers to a method of bypassing normal system authentication procedures?

- A. virus
- B. worm
- C. trojan horse
- D. spyware
- E. rootkits
- F. backdoor
- G. None of the choices.

Answer: F

Explanation:

A backdoor is a method of bypassing normal authentication procedures. Many computer manufacturers used to preinstall backdoors on their systems to provide technical support for customers. Hackers typically use backdoors to secure remote access to a computer, while attempting to remain hidden from casual inspection. To install backdoors, hackers prefer to use either Trojan horse or computer worm.

QUESTION 1084

To install backdoors, hackers generally prefer to use:

- A. either Trojan horse or computer worm.
- B. either Tripwire or computer virus.
- C. either eavedropper or computer worm.
- D. either Trojan horse or eavedropper.
- E. None of the choices.

Answer: A

Explanation:

A backdoor is a method of bypassing normal authentication procedures. Many computer manufacturers used to preinstall backdoors on their systems to provide technical support for customers. Hackers typically use backdoors to secure remote access to a computer, while attempting to remain hidden from casual inspection. To install backdoors, hackers prefer to use either Trojan horse or computer worm.

QUESTION 1085

In order to coordinate the activity of many infected computers, attackers have used coordinating systems known as:

- A. wormnets
- B. trojannets
- C. spynets
- D. botnets
- E. rootnets
- F. backdoor

Answer: D

Explanation:

In order to coordinate the activity of many infected computers, attackers have used coordinating systems known as botnets. In a botnet, the malware or malbot logs in to an Internet Relay Chat channel or other chat system. The attacker can then give instructions to all the infected systems simultaneously.

QUESTION 1086

In a botnet, malbot logs into a particular type of system for making coordinated attack attempts. What type of system is this?

- A. Chat system
- B. SMS system
- C. Email system
- D. Log system
- E. Kernel system
- F. None of the choices.

Answer: A

Explanation:

In order to coordinate the activity of many infected computers, attackers have used coordinating systems known as botnets. In a botnet, the malware or malbot logs in to an Internet Relay Chat channel or other chat system. The attacker can then give instructions to all the infected systems simultaneously.

QUESTION 1087

Which of the following software tools is often used for stealing money from infected PC owner through taking control of the modem?

- A. System patcher
- B. Porn dialer
- C. War dialer

- D. T1 dialer
- E. T3 dialer
- F. None of the choices.

Answer: B

Explanation:

One way of stealing money from infected PC owner is to take control of the modem and dial an expensive toll call. Dialer such as porn dialer software dials up a premium-rate telephone number and leave the line open, charging the toll to the infected user.

QUESTION 1088

Which of the following is an oft-cited cause of vulnerability of networks?

- A. software monoculture
- B. software diversification
- C. single line of defense
- D. multiple DMZ
- E. None of the choices.

Answer: A

Explanation:

An oft-cited cause of vulnerability of networks is homogeneity or software monoculture. In particular, Microsoft Windows has such a large share of the market that concentrating on it will enable a cracker to subvert a large number of systems. Introducing inhomogeneity purely for the sake of robustness would however bring high costs in terms of training and maintenance.

QUESTION 1089

Introducing inhomogeneity to your network for the sake of robustness would have which of the following drawbacks?

- A. poorer performance.
- B. poor scalability.
- C. weak infrastructure.
- D. high costs in terms of training and maintenance.
- E. None of the choices.

Answer: D

Explanation:

An oft-cited cause of vulnerability of networks is homogeneity or software monoculture. In particular, Microsoft Windows has such a large share of the market that concentrating on it will enable a cracker to subvert a large number of systems. Introducing inhomogeneity purely for the sake of robustness would however bring high costs in terms of training and maintenance.

QUESTION 1090

Which of the following may be deployed in a network as lower cost surveillance and early- warning tools?

- A. Honeypots
- B. Hardware IPSs
- C. Hardware IDSs
- D. Botnets
- E. Stateful inspection firewalls

- F. Stateful logging facilities
- G. None of the choices.

Answer: A

Explanation:

Honeypots, essentially decoy network-accessible resources, could be deployed in a network as surveillance and early-warning tools. Techniques used by the attackers that attempt to compromise these decoy resources are studied during and after an attack to keep an eye on new exploitation techniques.

QUESTION 1091

All Social Engineering techniques are based on flaws in:

- A. human logic.
- B. hardware logic.
- C. software logic.
- D. device logic.
- E. group logic.
- F. None of the choices.

Answer: A

Explanation:

Social engineering is a collection of techniques used to manipulate people into performing actions or divulging confidential information. While similar to a confidence trick or simple fraud, the term typically applies to trickery for information gathering or computer system access. All Social Engineering techniques are based on flaws in human logic known as cognitive biases. These bias flaws are used in various combinations to create attack techniques.

QUESTION 1092

Relatively speaking, firewalls operated at the application level of the sevenlayer OSI model are:

- A. almost always less efficient.
- B. almost always less effective.
- C. almost always less secure.
- D. almost always less costly to setup.
- E. None of the choices.

Answer: A

Explanation:

Early attempts at producing firewalls operated at the application level of the seven-layer OSI model but this required too much CPU processing power. Packet filters operate at the network layer and function more efficiently because they only look at the header part of a packet.

QUESTION 1093

Relatively speaking, firewalls operated at the physical level of the seven-layer OSI model are:

- A. almost always less efficient.
- B. almost always less effective.
- C. almost always less secure.
- D. almost always less costly to setup.
- E. None of the choices.

Answer: E

Explanation:

Early attempts at producing firewalls operated at the application level of the seven-layer OSI model but this required too much CPU processing power. Packet filters operate at the network layer and function more efficiently because they only look at the header part of a packet. NO FIREWALL operates at the physical level.

QUESTION 1094

Which of the following refers to the act of creating and using an invented scenario to persuade a target to perform an action?

- A. Pretexting
- B. Backgrounding
- C. Check making
- D. Bounce checking
- E. None of the choices.

Answer: A

Explanation:

Pretexting is the act of creating and using an invented scenario to persuade a target to release information or perform an action and is usually done over the telephone. It is more than a simple lie as it most often involves some prior research or set up and the use of pieces of known information.

QUESTION 1095

Pretexting is an act of:

- A. DoS
- B. social engineering
- C. eavedropping
- D. soft coding
- E. hard coding
- F. None of the choices.

Answer: B

Explanation:

Pretexting is the act of creating and using an invented scenario to persuade a target to release information or perform an action and is usually done over the telephone. It is more than a simple lie as it most often involves some prior research or set up and the use of pieces of known information.

QUESTION 1096

With Deep packet inspection, which of the following OSI layers are involved?

- A. Layer 2 through Layer 7
- B. Layer 3 through Layer 7
- C. Layer 2 through Layer 6
- D. Layer 3 through Layer 6
- E. Layer 2 through Layer 5
- F. None of the choices.

Answer: A

Explanation:

Deep packet inspection (DPI) is a form of computer network packet filtering that examines the data part of a through-passing packet, searching for non- protocol compliance or predefined criteria to decide if the packet can pass. DPI devices have the ability to look at Layer 2 through Layer 7 of the OSI model.

QUESTION 1097

Squid is an example of:

- A. IDS
- B. caching proxy
- C. security proxy
- D. connection proxy
- E. dialer
- F. None of the choices.

Answer: B

Explanation:

Squid is an example of a caching proxy, not a security proxy. It has the main purpose of locally storing copies of web pages that are popular, with the benefit of saving bandwidth.

QUESTION 1098

Which of the following types of firewall treats each network frame or packet in isolation?

- A. statefull firewall
- B. hardware firewall
- C. combination firewall
- D. packet filtering firewall
- E. stateless firewall
- F. None of the choices.

Answer: E

Explanation:

A stateless firewall treats each network frame or packet in isolation. Such a firewall has no way of knowing if any given packet is part of an existing connection, is trying to establish a new connection, or is just a rogue packet.

QUESTION 1099

Which of the following types of attack involves a program that creates an infinite loop, makes lots of copies of itself, and continues to open lots of files?

- A. Local DoS attacks
- B. Remote DoS attacks
- C. Distributed DoS attacks
- D. Local Virus attacks
- E. None of the choices.

Answer:

[Visit PassLeader and Download Full Version CISA Exam Dumps](#)